応用情報技術者試験　マネジメント系　No.16

システム監査

システム監査・内部統制

目次

1. 16-1 システム監査（63語）
2. 16-2 内部統制（38語）
3. まとめ

16-1 システム監査 まとめ表

監査の手続	
手続	内容
予備調査	監査対象の実態をつかみ、本調査の手順を決める
本調査	監査手続を行い、監査証拠を集める
評価・結論	証拠をもとに結論を出す
報告	監査報告書で指摘事項と改善勧告を伝える
フォローアップ	改善の状況を確かめる

16-1 システム監査 監査

システム監査
System Audit

独立した監査人が、情報システムのリスクへの対応を点検・評価し、保証や助言を行うこと

システム監査基準・システム管理基準
System Audit / Management Standards

監査人の行動規範と手順を定めたのが監査基準、監査で判断の尺度にする管理の実践規範が管理基準（経済産業省）

監査人の独立性
Independence

外観上（組織の上でも）と精神上（判断の上でも）の両方で、監査対象から独立していること

監査証拠
Audit Evidence

結論を裏付ける資料

ポイント 十分かつ適切であることが必要

監査調書
Audit Working Papers

監査人が行った手続と得た証拠を記録した文書

ポイント 結論の根拠になるので、きちんと作成し保管する

監査技法
Audit Techniques

チェックリスト法・ドキュメントレビュー法・インタビュー法・ウォークスルー法・突合せ法・現地調査法・CAAT（コンピュータ支援監査技法）など

16-1 システム監査 監査・監査の基本（発展）

テストデータ法
Test Data Method

監査人が用意したデータをプログラムで処理させ、結果が正しいかを確かめる技法

フォローアップ
Follow-up

改善勧告への対応状況を確かめること

ポイント 改善を行うのは監査を受けた部門

システム監査人
System Auditor

監査を行う人

ポイント 監査の対象から独立し、専門的な知識を持つ

監査報告書
Audit Report

監査の結論と、指摘事項・改善勧告を書いた報告書

ポイント 監査の依頼者（経営者）に出す

保証型監査・助言型監査
Assurance / Advisory Audit

保証型は管理が適切であることを保証する、助言型は改善のための助言を行う

外観上の独立性・精神上の独立性
Independence in Appearance / in Mind

監査の対象と身分や利害の関係がないことと、公平な態度で判断すること

16-1 システム監査 監査の基本（発展）

職業倫理と誠実性
Professional Ethics

監査人として、正直に公正に仕事をすること

専門職としての正当な注意
Due Professional Care

専門家として当然払うべき注意をもって監査すること

守秘義務
Confidentiality

監査で知った秘密を、ほかにもらさないこと

監査の目的
Audit Objectives

情報システムのリスクに対するコントロールが適切に整備・運用されているかを確かめ、保証や助言をすること

監査計画
Audit Planning

何を、いつ、どう監査するかを決めること

ポイント 中長期・基本・個別の計画がある

リスクアプローチ
Risk-based Approach

リスクの大きい所に重点を置いて監査すること

16-1 システム監査 監査の基本（発展）

予備調査
Preliminary Survey

本調査の前に、対象の概要や問題になりそうな所を調べること

本調査
Detailed Audit

予備調査をもとに、監査の手続きを行って証拠を集めること

監査手続
Audit Procedures

監査の証拠を集めるための具体的な方法

監査証拠の十分性・適切性
Sufficiency / Appropriateness

結論を出すのに足りる量があることと、信頼でき、目的に合っていること

監査の結論
Audit Conclusion

集めた証拠をもとに、監査人が下す判断

指摘事項
Audit Findings

監査で見つかった問題点

16-1 システム監査 監査の基本（発展）

改善提案
Recommendations

問題点を直すために、監査人が出す提案

ポイント 実際に直すのは監査を受けた側

監査報告
Audit Reporting

監査の結果を、監査を頼んだ人（経営者など）に報告すること

監査の依頼者
Audit Client

監査を頼み、報告を受ける人

ポイント 多くは経営者

被監査部門
Auditee

監査を受ける部門

外部監査・内部監査
External / Internal Audit

組織の外の専門家が行う監査と、組織の中の監査部門が行う監査

情報セキュリティ監査
Information Security Audit

情報セキュリティの対策が適切かを確かめる監査

ポイント 情報セキュリティ監査基準がある

16-1 システム監査 監査の基本（発展）・監査技法（発展）

個人情報保護監査
Privacy Audit

個人情報が決まりに沿って扱われているかを確かめる監査

監査の品質管理
Audit Quality Control

監査の進め方や結論が正しいかを、組織として確かめる仕組み

継続的監査
Continuous Auditing

ITを使って、データを常に見張りながら監査すること

CAAT
きゃっと / Computer Assisted Audit Techniques

コンピュータを使って行う監査の技法

Computer Assisted＝コンピュータで支援する／Audit Techniques＝監査の技法

質問法
Inquiry

関係者に質問して、答えを証拠にする方法

閲覧法
Inspection of Documents

文書や記録を読んで確かめる方法

16-1 システム監査 監査技法（発展）

観察法
Observation

実際の作業の様子を見て確かめる方法

突合・照合法
Reconciliation

関係する記録どうしを比べて、一致しているかを確かめる方法

例 入力の伝票と出力のリスト

再実施法
Reperformance

監査人が自分で同じ処理をやってみて、結果が同じかを確かめる方法

ウォークスルー法
Walkthrough

1つの取引を最初から最後までたどって、処理の流れを確かめる方法

チェックリスト法
Checklist

確かめる項目を一覧にして、それに答えてもらう方法

ITF法
あいてぃーえふ / Integrated Test Facility

本番のシステムに監査用の架空の口座を作り、テストデータを流して処理を確かめる方法

16-1 システム監査 監査技法（発展）

並行シミュレーション法
Parallel Simulation

監査人が用意したプログラムで同じデータを処理し、本番の結果と比べる方法

スナップショット法
Snapshot

処理の途中の決めた所でデータを書き出して、確かめる方法

タギング法
Tagging

特定の取引に印を付けて、その処理の流れを追う方法

監査モジュール法
Audit Module

本番のプログラムに、監査用の機能を組み込んでおく方法

ログ分析
Log Analysis

アクセスや操作の記録を調べて、不正や異常がないかを確かめる方法

サンプリング
Sampling

たくさんのデータから一部を選んで調べ、全体を推し量る方法

16-1 システム監査 監査技法（発展）・確かめる観点（発展）

電子的監査証拠
Electronic Audit Evidence

ログやデータなど、電子の形で集めた監査の証拠

ポイント 改ざんされていないかに注意する

特権IDの管理
Privileged ID Management

管理者の強い権限のIDを、使う人や使う時を限って管理すること

ポイント 使った記録を確かめる

運用の監査
Operations Audit

毎日の運用や障害の対応が、決まりどおり行われているかを確かめること

アクセス管理の監査
Access Control Audit

利用者IDや権限が、必要な人に必要な分だけ与えられているかを確かめること

開発の監査
Development Audit

要件定義や設計、テストの進め方が適切かを確かめること

外部委託の監査
Outsourcing Audit

外部の会社に頼んだ仕事が、契約どおり適切に行われているかを確かめること

16-1 システム監査 確かめる観点（発展）

受託業務の保証報告書
SOC報告書 / Service Organization Control Report

業務を引き受けた会社の内部統制について、外部の監査人が出す報告書

入力・処理・出力のコントロール
Input / Processing / Output Controls

データの入力の正しさ、処理の正しさ、出力の正しさを保つ仕組み

監査証跡
Audit Trail

誰がいつ何をしたかを後からたどれる記録

クラウドサービスの監査
Cloud Audit

クラウドを使うときの契約・データの置き場所・事業者の管理を確かめること

ポイント 事業者の第三者認証や報告書を活用する

AIシステムの監査
AI System Audit

AIの判断が公平で説明でき、決まりに沿って使われているかを確かめること

情報システム投資の監査
IT Investment Audit

システムへの投資が計画どおり効果を上げているかを確かめること

16-1 システム監査 確かめる観点（発展）

事業継続の監査
BCP Audit

災害のときの計画や訓練が適切かを確かめること

バックアップの監査
Backup Audit

バックアップが決まりどおり取られ、実際に戻せるかを確かめること

フォローアップ監査
Follow-up Audit

指摘した問題が、改善されたかを後から確かめること

16-2 内部統制 まとめ表

内部統制の基本的要素（日本の基準）
要素
統制環境
リスクの評価と対応
統制活動
情報と伝達
モニタリング
ITへの対応

16-2 内部統制 内部統制とガバナンス

内部統制
Internal Control

業務の有効性・効率性、財務報告の信頼性、法令の遵守、資産の保全を目的とした社内のしくみ

ポイント 経営者が整備・運用する責任を負う

職務分掌
Segregation of Duties

1人が業務のすべてを行わないよう、担当を分けること

ITガバナンス
IT Governance

経営の目標を達成するために、ITの活用を組織で統制するしくみ

ポイント JIS Q 38500は評価・指示・モニタの3つの活動を示す

COBIT
こびっと / Control Objectives for Information and related Technology

ITガバナンスとITマネジメントのための枠組み

Control Objectives=統制の目標／Information=情報／related Technology=関連技術

COSOフレームワーク
COSO Framework

内部統制の国際的な枠組み

ポイント 日本の基準はこれに「ITへの対応」を加えている

J-SOX
内部統制報告制度

上場企業の経営者に、財務報告に関する内部統制を評価・報告させる制度

ポイント 監査法人が監査する

16-2 内部統制 内部統制とガバナンス・内部統制とガバナンス（発展）

IT全般統制・IT業務処理統制
IT General / Application Controls

全般統制はシステムの開発・運用・アクセス管理などの基盤の統制、業務処理統制は入力・処理・出力のチェックなど個々の業務の統制

コンプライアンス
Compliance

法令や社内規程、社会の規範を守ること

内部統制の目的
Objectives of Internal Control

業務の有効性と効率性、財務報告の信頼性、法令の遵守、資産の保全の4つ

統制環境
Control Environment

経営者の考え方や組織の文化など、内部統制の土台

ポイント 内部統制の6つの基本的要素の1つ

リスクの評価と対応
Risk Assessment and Response

目的の達成を妨げるリスクを見つけて評価し、対応を決めること

統制活動
Control Activities

経営者の命令が確実に実行されるための方針や手続き

ポイント 承認・照合・職務の分担など

16-2 内部統制 内部統制とガバナンス（発展）

情報と伝達
Information and Communication

必要な情報を正しく集め、関係者に伝えること

モニタリング
Monitoring

内部統制がうまく働いているかを継続して見張り、評価すること

ポイント 日常的と独立的なものがある

ITへの対応
Response to IT

内部統制の目的を果たすために、ITを適切に使い、ITのリスクに対応すること

ポイント 日本の基準で加えられた要素

整備状況・運用状況
Design / Operating Effectiveness

統制の仕組みが正しく作られているかと、それが実際に守られているか

予防的統制・発見的統制
Preventive / Detective Control

問題が起きないようにする統制と、起きた問題を見つける統制

自動化された統制
Automated Control

システムが自動で行う統制

例 入力時の上限チェック

16-2 内部統制 内部統制とガバナンス（発展）

承認
Authorization

権限のある人が、取引や作業を認めること

アクセス権の定期的な見直し
Periodic Access Review

異動や退職に合わせて、利用者の権限を定期的に確かめ直すこと

経営者による評価
Management Assessment

経営者が、自社の内部統制が有効かを評価すること

ポイント 内部統制報告書を出す

内部統制報告書
Internal Control Report

財務報告に関わる内部統制が有効かを、経営者が報告する文書

内部統制監査
Internal Control Audit

経営者の内部統制報告書が正しいかを、外部の監査人が確かめること

不正のトライアングル
Fraud Triangle

不正は、動機・機会・正当化の3つがそろうと起きやすいという考え

16-2 内部統制 内部統制とガバナンス（発展）

3つのディフェンスライン
Three Lines Model

業務の部門、リスク管理の部門、内部監査の部門が、それぞれの立場でリスクを管理する考え方

コーポレートガバナンス
Corporate Governance

会社が健全に経営されるように、経営者を監視し、律する仕組み

ITガバナンスの原則
Principles of IT Governance

経営者がITの利用を評価・指示・モニタリングすること

ポイント JIS Q 38500で定められている

EDMモデル
Evaluate, Direct, Monitor

評価・指示・モニタリングを繰り返す、ITガバナンスの考え方

ITガバナンスの成熟度
IT Governance Maturity

ITガバナンスがどこまで進んでいるかを段階で表したもの

情報セキュリティガバナンス
Information Security Governance

情報セキュリティについて、経営者が方針を示し、取組みを見張る仕組み

16-2 内部統制 内部統制とガバナンス（発展）

リスクマネジメント
Risk Management

リスクを見つけ、評価し、対応し、見直す一連の活動

ポイント JIS Q 31000

法令遵守体制
Compliance Program

法律や社内の決まりを守るための仕組み

ポイント 行動規範・教育・内部通報など

内部通報制度
Whistleblowing System

社員が不正を見つけたとき、安全に知らせられる仕組み

ポイント 公益通報者保護法で守られる

企業倫理
Business Ethics

法律だけでなく、社会から見て正しい行動をとること

CSR
しーえすあーる / Corporate Social Responsibility

企業が社会や環境に対して持つ責任

ステークホルダへの説明責任
Accountability

経営の判断や結果を、関係者にわかるように説明する責任

16-2 内部統制 内部統制とガバナンス（発展）

SOX法
サーベンス・オクスリー法 / Sarbanes-Oxley Act

アメリカの会社の財務報告の信頼性を高めるための法律

ポイント J-SOXのもとになった

統制自己評価
CSA / Control Self-Assessment

業務を担当する部門が、自分たちで内部統制を評価すること

まとめ（1/2） この分野で覚える用語

小分類	用語
16-1 システム監査	システム監査・システム監査基準・システム管理基準・監査人の独立性・監査証拠・監査調書・監査技法・テストデータ法・監査報告書・フォローアップ・保証型監査・助言型監査・システム監査人・外観上の独立性・精神上の独立性・職業倫理と誠実性・専門職としての正当な注意・守秘義務・監査の目的・監査計画・リスクアプローチ・予備調査・本調査・監査手続・監査証拠の十分性・適切性・監査の結論・指摘事項・改善提案・監査報告・監査の依頼者・被監査部門・外部監査・内部監査・情報セキュリティ監査・個人情報保護監査・監査の品質管理・継続的監査・CAAT・質問法・閲覧法・観察法・突合・照合法・再実施法・ウォークスルー法・チェックリスト法・ITF法・並行シミュレーション法・スナップショット法・タギング法・監査モジュール法・ログ分析・サンプリング・電子的監査証拠・アクセス管理の監査・特権IDの管理・開発の監査・運用の監査・外部委託の監査・受託業務の保証報告書・入力・処理・出力のコントロール・監査証跡・クラウドサービスの監査・AIシステムの監査・情報システム投資の監査・事業継続の監査・バックアップの監査・フォローアップ監査

まとめ(2/2) この分野で覚える用語

小分類	用語
16-2 内部統制	内部統制・職務分掌・ITガバナンス・COBIT・COSOフレームワーク・J-SOX・IT全般統制・IT業務処理統制・コンプライアンス・内部統制の目的・統制環境・リスクの評価と対応・統制活動・情報と伝達・モニタリング・ITへの対応・整備状況・運用状況・予防的統制・発見的統制・自動化された統制・承認・アクセス権の定期的な見直し・経営者による評価・内部統制報告書・内部統制監査・不正のトライアングル・3つのディフェンスライン・コーポレートガバナンス・ITガバナンスの原則・EDMモデル・ITガバナンスの成熟度・情報セキュリティガバナンス・リスクマネジメント・法令遵守体制・内部通報制度・企業倫理・CSR・ステークホルダへの説明責任・SOX法・統制自己評価